

AdvocateAuroraHealth

Title: AAH Vulnerability Management Standard		Document Number: 62955
Document Type: ☐ Policy ☐ Procedure ☐ Guideline ☒ Other Standard		Last Review/Revision Date: 04/02/2021
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date: 04/02/2024
		Effective Date: 04/02/2021
Scope: ☐ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☒ Department Only (Department Name): HIT		

I. PURPOSE

The Advocate Aurora Health (AAH) Vulnerability Management Program standard establishes the requirements for scanning, identifying, communicating, overseeing the remediation of vulnerabilities discovered on the (Advocate Aurora) network and network devices.

II. SCOPE

This standard applies to all Information Resources owned or controlled by Advocate Aurora Health Care, Inc and its affiliated entities.

III. DEFINITIONS/ABBREVIATIONS

Advocate Aurora Information: All information that is owned by Advocate Aurora or owned by vendors, subcontractors, and/or business associates but provided to Advocate Aurora. For clarification purposes only, information remains "Advocate Aurora Information" even if it is in the possession and under the control of a vendor, subcontractor, and/or business associate.

Advocate Aurora Information Resources: Any media, software, hardware, or other technology that supports the use, access, processing, storage or transmission of Advocate Aurora Information.

Application Owner: A Team Member who is responsible for the application level technology aspects (e.g. implementation, maintenance, etc.) of a solution.

Business Owner: A Team Member who sponsors a solution's creation or who has a business need for the solution.

Common Vulnerabilities and Exposures (CVE): A list of publicly disclosed computer security flaws.

Common Vulnerability Scoring System (CVSS): A free and open industry standard for assessing the severity of security vulnerabilities. It is under the custodial care of the Forum of Incident Response and Security Teams (FIRST) of NIST. It provides a way to capture the principal characteristics of the vulnerability, and produce a numerical score reflecting its severity, as well as a textual representation of that score. The numerical score can then be translated into a qualitative representation (such as low, medium, high, and critical) to help organizations properly assess and prioritize their vulnerability management processes. The version used will be the most current which is compatible with the Vulnerability Management platform used at Advocate Aurora.

Exploit: Take advantage of a vulnerability or security flaw to gain access to Advocate Aurora assets. Exploit allows outside threat actors to gain access to the AAH infrastructure.

HIT Owner: A team member who is responsible for the technical components of a HIT asset, including but not limited to server, endpoint, or application

Host-specific credentials: Credentials for each device that will allow authentication into the device to scan for vulnerable software and configurations.

Remediation: The act of correcting the vulnerability or reducing a threat.

Remediation Plan: A documented course of action that details the steps needed for implementation of the solution to remediate the vulnerability by implementing the appropriate courses of action to avoid and mitigate the risk.

Risk Remediation: Risk Response in the larger NIST risk management framework. As defined in NIST publication 800-39, "risk response identifies, evaluates, decides on, and implements appropriate courses of action to accept, avoid, mitigate, share, or transfer risk to organizational operations and assets, individuals, other organizations, and the Nation, resulting from the operation and use of information systems."

Vulnerability: A weakness in an information system (hardware or software), system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source resulting in a negative impact to confidentiality, integrity, or availability.

Vulnerability management: The cyclical process of identifying, classifying, and remediating, and/or mitigating vulnerabilities to prevent the possible exploitation of vulnerabilities that may exist within AAH Information Resources.

Vulnerability Scanning: An automated process to proactively identify security weaknesses in a network or individual solution

IV. STANDARDS

A. Vulnerability Scanning Schedule

1. AAH should consider business functions and patient care to minimize impact on quality of service when scheduling vulnerability scans.
2. Scan at pre-schedule intervals or on an ad-hoc basis to meet business needs or projects.
3. The VM team must complete a vulnerability assessment of a server/system prior to the server/system being moved to production and it must be conducted on new products, assets, and services prior to go-live.

B. Vulnerability Scanning Detection

1. All AAH Information Resources should be scanned with host-specific credentials.
2. The vulnerability scanning solution will use the Common Vulnerability Scoring System (CVSS) to prioritize vulnerabilities that are identified through a scan.

C. Vulnerability Scanning Classification

1. All data gathered from the vulnerability scan and quarantine processes are regarded as AAH Legally Restricted Confidential Data as defined in the AAH Information Classification Policy.
2. Discovered vulnerabilities will be rated, using the CVSS score, to determine the risk the vulnerability poses to AAH.
3. Assets scanned will be identified and documented in the scanning application:

Severity Rating	CVSS Score	Days to Develop Remediation Plan	Days to Remediation & Mitigation
Info	0.0	N/A	N/A
Low	0.1 – 3.9	360 days	360 days
Medium	4.0 – 6.9	90 days	6 months
High	7.0 – 8.9	60 days	90 days
Critical	9.0 – 10.0	30 days	60 days

D. Vulnerability Remediation

1. Vulnerability Management Team will report vulnerabilities to HIT Owner.
2. HIT Owner must create a remediation plan within the timeframe associated with the CVSS score. The remediation plan process should include a timetable for routine application of patches and patch clusters based on patch criticality and the server environment.
3. Vulnerabilities should be remediated via automated monthly patch cycle or manually if additional testing is required.
4. Vulnerabilities that cannot be remediated within the required timeframe will require the HIT owner to complete a risk remediation evaluation by the HIT Security Risk Management team.

V. CROSS REFERENCES

AAH Security, Risk Management Program Policy
AAH Network Security Policy
AAH Server Security Integrated Policy
AAH Information Classification Policy
AAH Risk Remediation Standard
AAH EIS Standard Roles and Responsibilities

VI. RESOURCES AND REFERENCES

HITRUSTCSF v8	Control 10.m Control of Technical Vulnerabilities
HIPAA	§164.300 Security Rule
NIST-800-53	CA-2, CA-7, CM-4, CM-6, RA-2, RA-3, SA-11
SP 800-55 Rev. 2	A.2, B.3, B.4, B.8
PCI DSS version 3.2.1	6.1 & 6.2
Supported Compliance Controls:	
CIS Critical Security Controls	Control 3 - Continuous Vulnerability Management

VII. ATTACHMENTS

Not Applicable